

How Onam finds the paths that matter

From cloud inventory to a confirmed, MITRE-mapped, scored attack path — the method, end to end.

7 clouds

One property graph

Confirmed edges only

MITRE ATT&CK

Choke points

FAIR-style risk

THE ARGUMENT, IN ORDER

00	Executive summary	A finding is a fact.
01	The problem with a list	A modern multi-cloud estate generates findings faster than any team can trace them.
02	Ingestion — 7 clouds	Posture scanning connects through read-only cloud roles.
03	One data model — the property graph	Everything normalises into a single per-tenant property graph.
04	Search — BFS from entry to crown jewel	Search is breadth-first from entry points toward crown jewels...
05	Verification — confirmed edges only	A path that exists in the graph is a hypothesis, not a finding.
06	MITRE mapping, choke points, and risk	Each verified hop maps to a MITRE ATT&CK technique...
07	Summary	One claim, repeated at every stage: a finding is a fact, and only a verified route is a decision.

READS WITH [02 Cloud risk in dollars](#) · [03 One graph, one data model](#) · [04 Security & trust](#)

00 Executive summary

A finding is a fact. A verified path is a decision.

Every cloud scanner produces thousands of findings. The hard problem is not detection — it is knowing which handful of them combine into a route an attacker could actually walk to something that matters. Onam treats that as a graph-reasoning problem, solved the same way every time.

This paper describes the method end to end: how Onam inventories 7 clouds, normalises everything into one property graph, derives the relationships an attacker would exploit from evidence, searches for routes from entry points to crown jewels, and walks only the edges that evidence confirms. Each hop is mapped to a MITRE ATT&CK tactic and technique with a remediation step; the paths are scored on likelihood and impact; the choke points are marked; and findings on attack paths have their FAIR-style loss estimate raised, so the output reads in business terms rather than as a severity label.

The claim, precisely. Onam does not promise to block attacks at runtime. It promises something more useful for prioritisation: a reproducible, evidence-based map of the routes that exist in your cloud, rebuilt on every scan, with a deterministic identity for every finding so results are stable across rescans.

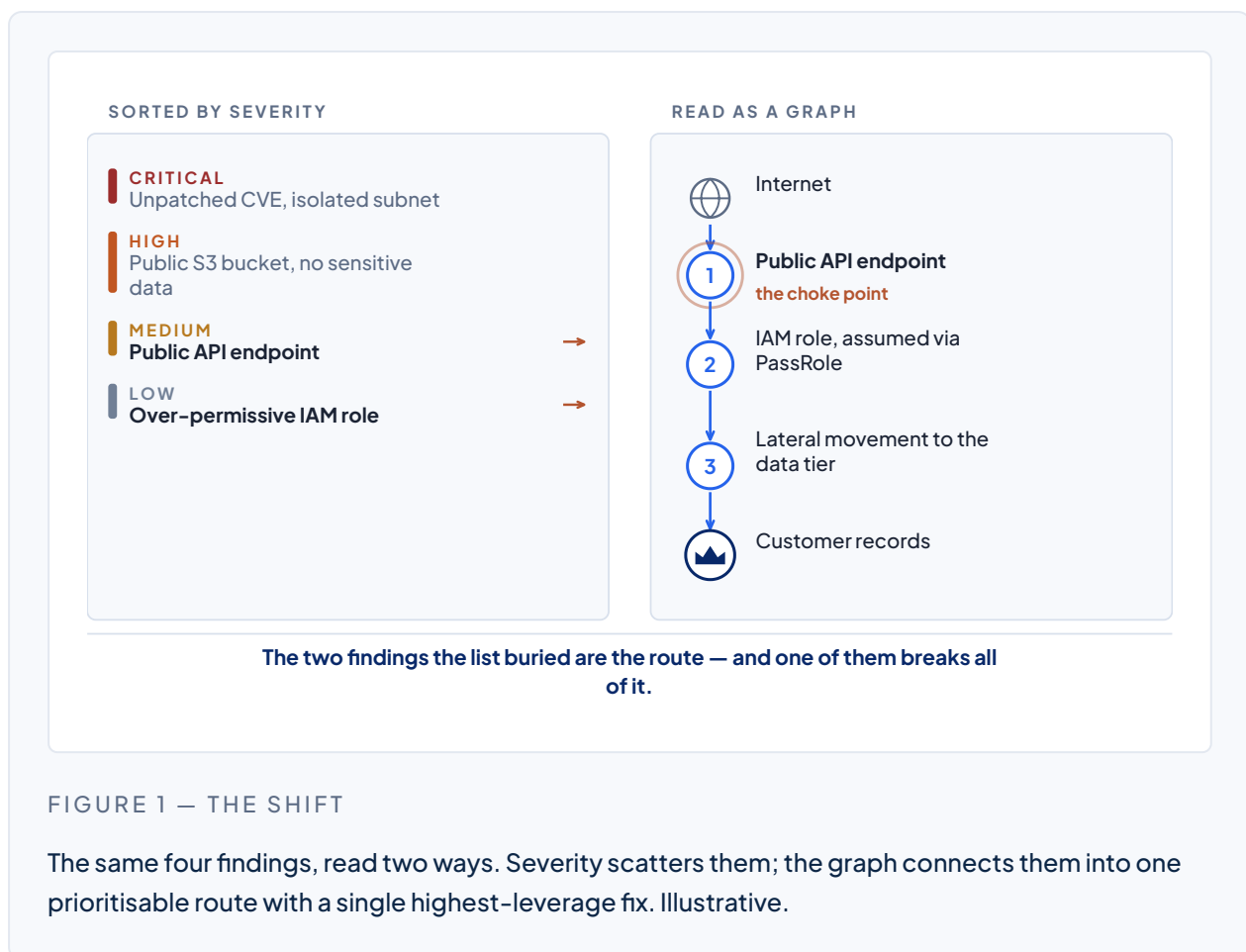
01 The problem with a list

A modern multi-cloud estate generates findings faster than any team can trace them. The industry's default answer is severity: sort by Critical, work down the list. But severity is a property of a finding **in isolation**. It cannot tell you that a "medium" public endpoint, a "low" over-permissive role and an unencrypted data store are — together — a single four-hop route to your customer records.

Attackers do not read your list. They chain. A route is only as strong as its weakest link, and the link that matters is rarely the one with the scariest CVSS score. To prioritise like a defender who thinks like an attacker, you have to reason over the relationships between findings, not the findings themselves.

02 Ingestion — 7 clouds

Posture scanning connects through read-only cloud roles; agentless workload scanning runs inside your account.



The method starts with telemetry that is safe to collect. Posture scanning connects to each cloud with the lowest privilege that permits a security read. On AWS Onam stores no secret — it assumes your role for short-lived credentials; where a cloud needs a stored credential, it is kept in AWS Secrets Manager, encrypted with AWS KMS. Agentless workload scanning is a separate mechanism that runs inside your account with its own permissions.

Cloud	Connection	Privilege posture
AWS	Cross-account IAM role via sts:AssumeRole, unique External ID per tenant	SecurityAudit + ReadOnlyAccess; STS credentials ≤ 60 min
Azure	Entra service principal	Reader + read-only Graph
GCP	Service account or keyless Workload Identity Federation	6 read-only roles
OCI	IAM user + signing key	inspect + read only
Alibaba / IBM	RAM read-only · Service ID	Read-only, exchanged for a short-lived Bearer token
Kubernetes	Read-only ServiceAccount	get / list / watch

Full detail of the trust model is in Whitepaper 04.

03 One data model — the property graph

Everything normalises into a single per-tenant property graph. Assets are nodes; edges are typed — containment, attachment, IAM trust and network reachability. Catalog-driven derives then add the *abuse* edges: the relationships an attacker would actually use, as distinct from the ones the cloud provider documents.

This is the step that makes cross-cloud reasoning possible at all. A path that starts in one provider and ends in another is only visible when both are described in the same vocabulary. Architecture detail is in Whitepaper 03.

04 Search — BFS from entry to crown jewel

Search is breadth-first from entry points — the internet, admin and other identities, CI/CD, third parties and other clouds — toward crown jewels: the data stores, keys and other high-value resources a path can end at. Breadth-first matters: it finds the *shortest* route first, and likelihood decays with every hop, so shorter routes score higher.

05 Verification — confirmed edges only

A path that exists in the graph is a hypothesis, not a finding. Every edge carries a verdict from the evidence behind it — posture, identity, network, data and threat-detection signals — and is marked confirmed, blocked or a gap. Search walks only confirmed edges.

Why this gate exists. An unverified path is worse than no path: it spends a security team's credibility on a route that may not exist. Verification is the difference between a graph that suggests and a graph that asserts.

06 MITRE mapping, choke points, and risk

Each verified hop maps to a MITRE ATT&CK technique, so the route reads as an attack narrative rather than a list of resource IDs, and each hop carries a remediation step. Paths are scored on likelihood and impact: a WAF or MFA confirmed on the route lowers the score, a high-EPSS vulnerability on a node raises it. The choke point — the node appearing on the most confirmed routes — is marked, with the number of paths fixing it would block.

Finally, findings that sit on attack paths have their FAIR-style loss estimate raised, so the paths carry business weight in the risk view. Method detail is in Whitepaper 02.

07 Summary

One claim, repeated at every stage: a finding is a fact, and only a verified route is a decision.

- Severity ranks findings against each other; a graph ranks routes against reality.
- 7 clouds into one property graph with typed abuse edges, built from evidence.
- Breadth-first search from entry points to crown jewels.
- Only edges confirmed by evidence are walked.
- MITRE mapping for narrative, choke points for leverage, a FAIR-style estimate for business weight.
- Onam does not block at runtime. It tells you, reproducibly, which few fixes matter most.